Note de sécurité : Sentinelle

Équipe Harmattan, École Polytechnique de Ouagadougou. Version du prototype soumis au sprint pré-hackathon 2026.

1. Principe et périmètre

Le serveur est considéré comme **non digne de confiance pour le contenu** : un administrateur du serveur, un attaquant qui vole sa base ou qui écoute le réseau ne doivent pouvoir lire ni message ni fichier. Le chiffrement de bout en bout repose sur **Matrix (Olm/Megolm)**, implémenté par Element Web (vodozemac). **L'équipe n'a écrit aucune cryptographie.** Le serveur (Synapse) ne stocke que des événements `m.room.encrypted`, et les fichiers sont chiffrés par le client avant envoi. Ce point est vérifiable en direct avec `scripts/verify-no-plaintext.sh`.

2. Menaces prises en compte et protections

Menace	Protection mise en place
Lecture des messages par le serveur ou son administrateur	E2EE obligatoire par défaut sur toutes les salles (`encryption_enabled_by_default_for_room_type: all`) ; salles créées par le portail avec chiffrement imposé dès la création ; script de preuve sur la base et les médias
Écoute du réseau	Le contenu reste chiffré de bout en bout, même si le transport est lu. TLS obligatoire en production (voir limites)
Vol ou devinette d'un mot de passe	Second facteur **TOTP** exigé à la première connexion, mot de passe de 12 caractères minimum, verrouillage après 5 échecs, sessions SSO de 30 minutes d'inactivité. Aucun mot de passe Matrix n'existe (connexion par SSO uniquement)
Intrus non enrôlé	Pas d'inscription libre (Keycloak et Synapse), seuls les comptes créés par le portail existent ; Synapse exige le rôle `agent` ou `admin-si` dans le jeton ; salles sur invitation ; **aucune fédération**
Agent qui part, téléphone perdu	**Révocation unique** : compte Keycloak désactivé et sessions fermées, compte Synapse désactivé (jetons invalidés, salles quittées), appareils supprimés, puis vérification finale (compte inactif, 0 appareil, 0 salle) et entrée au journal d'audit. Les clients restants renouvellent la clé de groupe quand un membre quitte : l'agent révoqué ne lit pas les nouveaux messages
Détournement du portail	Accès réservé au rôle `admin-si`, contrôlé côté serveur après SSO ; jeton CSRF sur toute action ; en-têtes de sécurité (CSP, no-store, nosniff) ; **origine distincte d'Element** (`admin.localhost` et `chat.localhost`) : une faille du portail ne donne pas accès aux clés du navigateur ; compte de service Keycloak à droits minimaux ; un administrateur ne peut pas se révoquer lui-même ; chaque action est journalisée
Accès à l'API d'administration de Synapse	`/_synapse/admin` n'est jamais exposé par le proxy ; seul le portail l'atteint, sur le réseau interne
Fuite vers des tiers	Pas de fédération, pas d'aperçu d'URL, pas de CDN, pas d'analytique, pas de cartes ni d'intégrations dans Element, pas de service de notification externe
Conservation excessive	Expiration automatique des messages côté serveur sur les canaux classifiés (24 h pour Confidentiel, 30 jours pour Diffusion restreinte) ; appareils inactifs supprimés après 30 jours

3. Ce que le serveur voit malgré tout (métadonnées)

Le serveur voit : les identifiants et noms des comptes ; **qui est membre de quelle salle** ; les **noms et sujets des salles** (non chiffrés dans Matrix) ; pour chaque message, **l'expéditeur, la salle, l'horodatage et la taille** ; les appareils enregistrés ; les adresses IP des connexions.

Mesures pour le réduire : présence désactivée (pas de « en ligne » ni « vu à ») ; aperçus d'URL désactivés (le serveur ne contacte jamais un site tiers) ; adresses IP et agents utilisateurs conservés **1 jour** seulement ; **aucun journal d'accès HTTP** côté Synapse ; pas d'adresse e-mail ni de téléphone collectés ; aucune fédération (les métadonnées ne quittent pas le serveur) ; messages purgés automatiquement sur les canaux classifiés. L'annuaire des agents est volontairement visible de tous les agents enrôlés : c'est la fonction d'annuaire officiel.

4. Limites connues (assumées)

1. **Transport** : la démonstration tourne en HTTP sur la boucle locale. En production, TLS est indispensable (Caddy avec un domaine réel), sinon les jetons de session circulent en clair.
2. **Secrets de démonstration** : les mots de passe et secrets du dépôt sont fictifs et doivent être changés avant tout déploiement réel.

3. **Appareil volé** : la révocation coupe l'accès au serveur, elle n'efface pas les messages déjà déchiffrés et stockés sur l'appareil. Atténuations : chiffrement du disque, expiration des messages. L'effacement à distance n'est pas implémenté. Une révocation faite par erreur se corrige par la **réactivation** du portail (journalisée) : l'agent repart sans appareil, sans salle et avec un nouveau second facteur, il ne retrouve pas ses anciens messages chiffrés. De même, l'expiration est appliquée par le serveur ; un navigateur peut conserver un message expiré dans son cache local jusqu'à ce que celui-ci soit vidé (constaté lors de nos essais).
4. **Serveur malveillant** : dans Matrix, un administrateur de serveur peut chercher à ajouter un appareil pour un agent. La vérification croisée des appareils (cross-signing) et l'option Element « ne jamais envoyer aux sessions non vérifiées » en limitent l'effet ; elles ne sont pas imposées dans ce prototype.
5. **Second facteur** : il est imposé par une action requise Keycloak à la création du compte par le portail. Un compte créé à la main hors du portail pourrait y échapper ; la page « Conformité » du portail les signale. En production, un flux d'authentification imposant le TOTP à tous est recommandé.
6. **Console Keycloak** accessible sur le même proxy : à restreindre au réseau d'administration en production.
7. **Captures d'écran et transfert** : non bloquables dans un client web. Ces fonctions nécessiteraient une application native.
8. **Sauvegarde des clés** : la perte des clés d'un agent entraîne la perte de son historique chiffré.
9. **Disponibilité et audit** : un seul serveur, aucun audit externe ni test d'intrusion indépendant à ce stade. Les tests automatisés couvrent la logique du portail (48 tests).